

Strategia bezpieczeństwa wobec AI-Driven Attacks pod presją wdrażania AI — badanie falsyfikacyjne Monte Carlo

Executive summary

Badanie bazowe „Security Model Boundary” przyjmuję wyłącznie jako **evidence baseline / prior**, nie jako prawdę wejściową. Jego centralne konstrukcje — Security Model Boundary, Probabilistic-Deterministic Boundary, Security Observability Kernel, Combinatorial Execution Control i Security Boundary Buffer — zostały ponownie skonfrontowane z aktualnymi źródłami pierwotnymi.

Wymagania eksperymentu Monte Carlo, w tym $N=1\ 000\ 000$, porównanie strategii, falsyfikacja, stress testing i optymalizacja wielokryterialna, pochodzą z dostarczonego projektu badawczego.

Werdykt hipotezy: CZĘŚCIOWO POTWIERDZONA — STRONG EVIDENCE dla mechanizmu, WEAK EVIDENCE dla jego absolutnej częstości. Najmocniejsza część tezy przetrwała: bezpieczeństwo elementów ocenianych lokalnie nie gwarantuje bezpieczeństwa aktywowanej ścieżki ich kompozycji. SCR-Bench raportuje właśnie wzorzec „benign in isolation, harmful in composition”; trzeba jednak zaznaczyć, że jest to preprint z czerwca 2026, więc jest mocnym sygnałem badawczym, ale nie ustalonym standardem naukowym. AgentDojo, CaMeL, FIDES, NIST i bieżąca dokumentacja Microsoftu niezależnie wspierają przesunięcie uwagi z samego outputu LLM na przepływ danych, capabilities, trust boundaries, tool calls i consequential actions. ¹

STRONG EVIDENCE: granica `probabilistic decision → deterministic side effect` jest realnym punktem kontroli. Microsoft Research w FIDES formalizuje deterministic policy enforcement i information-flow control, a Microsoft Security wprost opisuje application layer jako warstwę, która zamienia probabilistyczne zachowanie modelu w deterministyczne skutki systemowe. OpenAI stosuje analogiczne rozumowanie source-sink: niezaufane źródło staje się niebezpieczne dopiero w połączeniu z consequential capability. ²

STRONG EVIDENCE: statyczne „one-and-done security” jest niewystarczającą strategią dla części klas ataków AI. NIST pokazuje zarówno konieczność post-deployment monitoring, jak i bardzo dużą różnicę między statycznymi a adaptacyjnymi testami agent hijacking: dla badanego modelu na AgentDojo najmocniejszy baseline dawał 11% attack success, podczas gdy nowy atak dostosowany przez red team do modelu osiągnął 81%. NIST opublikował też w 2026 formalny wynik wskazujący ograniczenia uniwersalnej odporności skończonego zestawu guardrails wobec adaptacyjnych adversarial prompts; zakres tego dowodu nie obejmuje całego cyberbezpieczeństwa agentów, ale silnie wspiera ciągły model red-team-update-resilience. ³

STRONG/MODERATE EVIDENCE: presja rozwojowa nie jest hipotetyczna, ale jej wartość ekonomiczna jest silnie heterogeniczna. Badanie NBER na 5 179 agentach customer support wykazało średnio 14% wzrost produktywności i znacznie większy efekt dla mniej doświadczonych pracowników; inne badanie terenowe obejmujące 66 firm i 7 137 knowledge workers wykazało oszczędność około dwóch godzin e-maila tygodniowo wśród aktywnych użytkowników, lecz bez wykrywalnej zmiany ogólnej kompozycji

pracy. Z drugiej strony RCT METR z 2025 pokazał dla doświadczonych open-source developers 19% wydłużenie czasu realizacji zadań z ówczesnymi narzędziami AI. Dlatego w modelu **nie wolno** zakładać stałego „+X% productivity from AI”; potrzebny jest szeroki rozkład z możliwością wartości ujemnych. ⁴

Wykonałem rzeczywistą symulację: **1 000 000 wspólnych światów losowych × 36 strategii**, z hierarchią WORLD→ORGANIZATION→INCIDENT, 12 klasami organizacji, 10 klasami przeciwnika, heavy-tail loss model, 32 control primitives i Common Random Numbers. Następnie wykonałem sprawdzenie konwergencji `1k→10k→100k→250k→500k→1M`, 100 kontrfaktycznych światów falsyfikacyjnych, 20 nazwanych stress tests, Morris screening, estymację first-order Sobol oraz adversarial random search przybliżający `argmax failure world`.

Najważniejszy wynik nie brzmi „S22 jest obiektywnie najlepszą strategią”. Brzmi:

MODERATE EVIDENCE / MODEL-CONDITIONAL: przy przyjętych jawnie parametrach kalibracyjnych strategia z federacyjnym enforcementem, provenance, capability control, deterministic gates i observability daje najlepszy robust trade-off spośród strategii, które spełniły ustalone ograniczenie tail risk.

Nominalnie najwyższy strategiczny wynik spośród strategii spełniających podstawowe ograniczenie osiągnęła **S31 Provenance+Capability**. Jednak w 100 kontrfaktycznych światach jej `P95` modelowanego catastrophic risk wyniosło 1,1235%, przekraczając roboczy robust-risk limit 1%. **S22 Federated Security Control** miało nieco niższą korzyść, lecz `P95 catastrophic risk = 0,7802%` i najmniejszy minimax/mean regret wśród strategii, które przeszły ten test. Dla infrastruktury krytycznej właściwy wybór przesuwają się dalej w stronę S27/S35.

W praktyce wyniki przemawiają więc nie za jednym profilem, lecz za **trzema pasami autonomii**:

Pas	Zastosowanie	Preferowany profil
GREEN	read-only, reversible, niski impact	S31-like: provenance + capabilities, wysoka szybkość
AMBER	write/action, przekraczanie trust boundaries	S22/S30/S09-like: federated enforcement + deterministic boundary
RED	critical/irreversible/high-authority	S27/S35-like: path-aware enforcement, isolation, invariants, red team, recovery, selective human gate

To umożliwia wdrażanie AI zamiast blokowania go: **autonomia jest funkcją consequentiality, provenance i observability, a nie binarnym „AI allowed / AI forbidden”**.

Pełny pakiet reprodukcji: [SMB-MC reproducibility package](#).

Kod wykonanej symulacji: [simulation.py](#).

Wyniki `N=1M`: [strategy_summary.csv](#).

Jawny rejestr założeń: [assumptions_register.csv](#).

Reweryfikacja dowodów i falsyfikacja hipotezy

Najpierw najważniejsze falsyfikacje.

FACT: bezpieczeństwo kompozycyjne nie jest nową dziedziną wynalezioną przez agentic AI. Capability security, information-flow control, taint tracking, least privilege i isolation są wcześniejszymi koncepcjami. Współczesne rozwiązania takie jak CaMeL i FIDES właśnie je adaptują do LLM agents. Dlatego twierdzenie „klasyczny security model nie potrafi w ogóle reprezentować kompozycji” należy odrzucić. ⁵

FACT: również Zero Trust nie jest automatycznie sfalsyfikowany przez AI. Microsoft w 2026 wprost rozszerza zasady verify explicitly, least privilege i assume breach na agentic systems. Problem nie polega więc na tym, że cały istniejący security engineering jest błędny; polega na tym, że jego enforcement musi obejmować nowe trust boundaries i dynamiczne agent workflows. ⁶

UNSUPPORTED: nie znalazłem podstaw do twierdzenia, że producenci świadomie pominęli tę klasę problemów, ponieważ „nie chcą płacić kosztu obliczeniowego” i próbują ją ukrywać. Wręcz przeciwnie: NIST, Microsoft, OpenAI i Google publicznie opisują koszty, trade-offy i niewystarczalność pojedynczych warstw kontroli. Hipoteza o **Security Model Debt** pozostaje sensowna jako konstrukcja ekonomiczno-architektoniczna, lecz intencjonalność producentów jest nieudowodniona. ⁷

To, co **przetrwało** falsyfikację, jest węższe i silniejsze:

Twierdzenie	Ocena	Wynik reweryfikacji
Lokalnie bezpieczne elementy mogą dać niebezpieczną kompozycję	STRONG/MODERATE	SCR-Bench bezpośrednio raportuje path-level composition risk; status preprint. ⁸
Agent security wymaga adaptive evaluation	STRONG	NIST: 11%→81% ASR po adaptacji ataku; repeated attempts także znacząco zmieniają ocenę ryzyka. ⁹
Consequential tool boundary powinien mieć niezależny enforcement	STRONG	FIDES i Microsoft defense-in-depth. ¹⁰
Input filtering sam nie wystarcza	STRONG	OpenAI zaleca ograniczanie skutków manipulacji i source-sink controls. ¹¹
End-to-end observability/provenance jest potrzebne	STRONG	NIST AI 800-4 i Microsoft wskazują na fragmented logging, potrzebę trace context i forensic reconstruction. ¹²
AI zwiększa ofensywną automatyzację/chaining	STRONG/MODERATE	GTIG raportuje agentic workflows i autonomous orchestration; Anthropic widzi AI w całym ATT&CK chain. ¹³
Możliwe są realne długie cyber chains wykonywane przez modele	STRONG, lecz szczególny przypadek	Incydent OpenAI/Hugging Face obejmował zero-day, privilege escalation, lateral movement i chaining; był to jednak specjalny eval z modelami o zmniejszonych cyber-refusals, nie normalny production deployment. ¹⁴

Twierdzenie	Ocena	Wynik reweryfikacji
Pełna prewencja przez stały zestaw guardrails rozwiązuje problem	SFALSYFIKOWANE w zakresie adaptive prompt attacks	NIST wskazuje formalne ograniczenia i potrzebę continuous monitor-and-update. ¹⁵

Microsoft podał szczególnie trafny przykład observability gap: research agent może pobrać zatruty materiał, przekazać go jako zaufany kontekst kolejnemu agentowi, a ten wykonać niebezpieczną operację, podczas gdy tradycyjne latency/error/uptime metrics pozostają poprawne. To jest bardzo mocne wsparcie dla tezy, że jednostką obserwacji musi być przynajmniej **causal execution path**, a nie tylko health komponentów. ¹⁶

Równocześnie dane z realnego threat intelligence nie uzasadniają jeszcze zbudowania globalnej tabeli „roczne prawdopodobieństwo AI-driven compromise = X”. Anthropic analizuje wybrany zbiór 832 zbanowanych kont, a GTIG swoje obserwacje z telemetry, incident response i threat research; są to niezwykle wartościowe dowody mechanizmu i trendu, ale nie losowa próba całego Internetu. Dlatego częstotści ataków w Monte Carlo pozostają **CALIBRATION**, a nie **OBSERVED**. ¹⁷

Model formalny i konstrukcja eksperymentu

Podstawową jednostką jest trajektoria:

$$\tau = (s_0, a_1, s_1, \dots, a_n, s_n)$$

i klasyczny przypadek graniczny:

$$\forall i \text{ Allowed}(a_i, s_i) = 1$$

przy jednoczesnym:

$$Safe(\tau) = 0$$

Definiuję:

$$SMB = \{\tau \in R : ModelAccepts(\tau) = 1 \wedge SecurityInvariant(\tau) = 0\}$$

oraz:

$$SMBE = \{\tau \in SMB : \tau \text{ jest indukowana lub wykorzystywana przez przeciwnika}\}$$

PDB — Probabilistic–Deterministic Boundary jest przejściem:

$$a_t \sim \pi_\theta(a|context_t)$$

po którym następuje:

$$s_{t+1} = F(s_t, a_t)$$

gdzie **F** może oznaczać realne **SEND**, **WRITE**, **EXECUTE**, **GRANT**, **DELETE**, **DEPLOY**, **TRANSFER** albo zmianę polityki.

Struktura Monte Carlo była hierarchiczna:

$$W_i \sim P(W)$$

$$O_i \sim P(O|W_i)$$

$$A_i \sim P(A|W_i, O_i)$$

$$I_i \sim P(I|W_i, O_i, A_i, S)$$

$$L_i \sim P(L|I_i, W_i, O_i, A_i, S)$$

gdzie S jest strategią.

Łańcuch incydentu:

Discovery → *InitialAccess* → *Reachability* → *Composition* → *PolicyInteraction* → *Authority* → *Execution*

jest modelowany etapowo, a następnie prekompilowany do bazowej path probability. Ta kompilacja była **MODEL SIMPLIFICATION** wymuszona kosztami wykonania, nie założeniem, że etapy są semantycznie równoważne.

Annualized compromise model ma postać:

$$P_{comp} = 1 - \exp(-\lambda P_{path})$$

a P_{path} jest modyfikowane przez latentne $P(SMBE)$ oraz $P(PDB-failure)$.

Nie traktuję tu miliona realizacji jako miliona danych empirycznych. NIST AI 800-3 właśnie przed takim pomieszaniem estymandu, założeń i uncertainty przestrzega: model statystyczny powinien jawnie określać, co właściwie jest mierzone, a szersza generalizacja wymaga dodatkowych założeń. ¹⁸

Rejestr parametrów

Parametr	Model	Status epistemiczny
threat_pressure	lognormal transform latent Gaussian	CALIBRATION
offensive_AI	logistic-normal	CALIBRATION
development_pressure	logistic-normal	CALIBRATION
ecosystem_complexity	logistic-normal	CALIBRATION
supply_chain_pressure	logistic-normal	CALIBRATION
defensive_AI	logistic-normal	CALIBRATION
organizacja	12-klasowy categorical	CALIBRATION
adversary	A0-A9 categorical	CALIBRATION
productivity delta	clipped $\text{Normal}(0.11, 0.13)$, $[-0.25, 0.55]$	CALIBRATION ENVELOPE , nie fitted empirical distribution
loss body	lognormal	CALIBRATION

Parametr	Model	Status epistemiczny
extreme tail	Pareto, $\alpha=1.75$	CALIBRATION / STRESS
control effectiveness	profile $0..1$ × operational attenuation	CALIBRATION
base attack-stage logits	osiem wartości modelowych	CALIBRATION
katastroficzny risk appetite	nominalnie $\leq 0.1\%$	CALIBRATION / governance input
robust counterfactual limit	$P95 \leq 1\%$	CALIBRATION , nie rekomendowany uniwersalny limit
NSV weights	$utility - 75L - 8cost - .35delay$	CALIBRATION / MCDM preference

Wartość 0.11 dla productivity **nie oznacza**, że literatura dowodzi uniwersalnego 11% gain. Wybrałem rozkład z szerokim rozrzutem i ujemnym ogonem właśnie dlatego, że wyniki terenowe wahają się od istotnych korzyści do spowolnienia zależnie od zawodu, doświadczenia i generacji narzędzia. ¹⁹

Model korelacji

Macierz poniżej jest jawnie **CALIBRATION**, nie estymacją z danych:

	Threat	Off-AI	Dev pressure	Ecosystem	Supply	Def-AI
Threat	1.00	.45	.55	.20	.35	-.10
Off-AI	.45	1.00	.55	.15	.45	-.05
Dev pressure	.55	.55	1.00	.25	.50	.05
Ecosystem	.20	.15	.25	1.00	.20	-.10
Supply	.35	.45	.50	.20	1.00	.05
Def-AI	-.10	-.05	.05	-.10	.05	1.00

W produkcyjnym badaniu tę macierz należy zastąpić posteriorami z telemetry organizacji, incident history, attack-path testing, red-team results i danych o faktycznym wykorzystaniu AI.

Hierarchia organizacji i przeciwników

Symulacja rozróżnia SME, Enterprise, Global Enterprise, AI-native, Software, Finance, Healthcare, Industrial, Critical Infrastructure, Cloud Provider, Government i Defense.

A0-A9 reprezentują przejście od opportunistic human przez human+AI, semi-autonomous i multi-agent offensive systems po wysokocapability adaptive adversary. Ich częstość i capability score są **CALIBRATION**; bieżące dane GTIG i Anthropic uzasadniają uwzględnienie agentowej automatyzacji jako scenariusza, ale nie pozwalają jeszcze wiarygodnie wyznaczyć globalnych wag A0-A9. ¹⁷

Biblioteka zawiera 32 controls, m.in. `inventory`, `unique_identity`, `least_privilege`, `ephemeral_credentials`, `tool_allowlist`, `parameter_validation`, `deterministic_gate`, `information_flow_taint`, `context_provenance`, `runtime_tracing`, `invariant_checks`, `sandboxing`, `microsegmentation`, `memory_segregation`, `RAG trust segmentation`, `egress restriction`, `bounded recursion`, selective approvals, circuit breakers, rollback, anomaly detection, continuous boundary red team, AI defender, supply-chain validation, execution receipts, short-lived tokens, quotas, kill switch, adaptive containment, attack-path exploration i runtime policy hooks. Takie grupy zabezpieczeń mają bezpośrednie odpowiedniki w obecnych kierunkach NIST, Microsoft, FIDES/CaMeL i OpenAI, choć **ich efektywności liczbowe w symulacji pozostają kalibracyjne**. ²⁰

Porównano 36 strategii:

S00-S11	S12-S23	S24-S35
S00 Maximum AI Acceleration	S12 Continuous Boundary Red Team	S24 Minimal Effective Controls
S01 Compliance Baseline	S13 AI-vs-AI Defense	S25 Maximum Prevention
S02 Classical Zero Trust	S14 Maximum Blast-Radius Reduction	S26 Maximum Resilience
S03 Human-in-the-Loop	S15 Fast Detection-Recovery	S27 SMB Program
S04 Human-on-the-Loop	S16 Identity-Centric	S28 Adaptive Security Envelope
S05 Deterministic Gate	S17 Provenance-Centric	S29 Pareto Hybrid Seed
S06 Capability Security	S18 Information-Flow Security	S30 Lean Deterministic Envelope
S07 Isolation/Sandbox	S19 Adaptive Authority	S31 Provenance+Capability
S08 Maximum Observability	S20 Risk-Budgeted Autonomy	S32 RedTeam+Deterministic
S09 Security Boundary Buffer	S21 Multi-Agent Segmentation	S33 Segmented Adaptive Envelope
S10 Path-Aware Enforcement	S22 Federated Security Control	S34 High-Velocity Safe Deploy
S11 Invariant-Driven	S23 Centralized Enforcement Plane	S35 Critical Infrastructure Envelope

Porównania używają **Common Random Numbers**: każda strategia dostaje ten sam `world_i`, ten sam adversary i te same realizacje losowe incydentu, dzięki czemu porównujemy polityki na tych samych warunkach. CRN jest klasyczną metodą redukcji wariancji porównań, choć literatura pokazuje również przypadki, w których niewłaściwe użycie może wariancję zwiększać; zatem samo zastosowanie CRN nie jest gwarancją poprawy. ²¹

Morris został użyty jako tani screening global sensitivity, natomiast Sobol jako wariacyjna kontrola pierwszego rzędu. Wybór tych metod jest zgodny z ich pierwotnym przeznaczeniem: Morris do identyfikacji istotnych wejść przy dużym modelu, Sobol do rozkładania wariancji między czynniki. ²²

Rdzeń implementacji:

```
rng = np.random.default_rng(20260818)

world = draw_correlated_worlds(N=1_000_000)
org = draw_organization(world)
adversary = draw_adversary(world, org)

# Common Random Numbers
u_comp, u_cat, z_loss, u_tail = draw_once_for_all_strategies()

for strategy in strategies:
    p_path = attack_chain_probability(world, org, adversary)

    p_path *= smb_boundary_factor(strategy, world)
    p_path *= pdb_boundary_factor(strategy, world)
    p_path *= control_attenuation(strategy, world, org)

    p_comp = 1 - np.exp(-attack_intensity * p_path)

    compromise = u_comp < p_comp
    catastrophic = compromise & (u_cat < p_catastrophic)

    loss = heavy_tailed_loss(compromise, z_loss, u_tail)
    utility = ai_utility(strategy, world, org)
    velocity = deployment_velocity(strategy, world, org)

    NSV = utility - 75 * loss - 8 * control_cost - 0.35 * delay

    summarize(
        median=True,
        variance=True,
        p90=True,
        p95=True,
        p99=True,
        cvar95=True,
        cvar99=True
    )
```

Pełna wersja wykonywalna znajduje się w [simulation.py](#).

Wyniki Monte Carlo, Pareto i falsyfikacja strategii

Najważniejsza zasada interpretacji:

Poniższe prawdopodobieństwa są wynikami modelu, nie prognozami empirycznymi.

1 000 000 realizacji redukuje **Monte Carlo sampling error** dla danego modelu. Nie redukuje błędu wynikającego z błędnych priors, nieznanych correlations, źle określonych control effect sizes ani pominiętej zmiennej.

Wybrane wyniki nominalne:

Strategia	NSV	Model P(cat)	CVaR99 loss	AI utility	Velocity	Cost index	SMD
S00 Max Acceleration	49.51	2.5627%	.7266	58.80	79.66	.005	.742
S01 Compliance	48.43	1.2017%	.5119	57.96	77.41	.047	.734
S31 Provenance+Capability	50.21	.0766%	.0803	61.22	73.63	.173	.304
S22 Federated Control	48.98	.0516%	.0515	60.61	72.19	.206	.476
S30 Lean Deterministic	47.82	.0461%	.0440	59.75	71.11	.208	.307
S34 High-Velocity Safe	47.09	.0324%	.0328	59.38	70.95	.249	.173
S09 Boundary Buffer	46.60	.0248%	.0280	59.17	69.51	.238	.189
S27 SMB Program	43.11	.0047%	.0058	57.39	66.83	.366	.013
S28 Adaptive Envelope	38.03	.0017%	.0016	54.13	61.87	.433	.016
S35 Critical Infra	34.92	.0008%	.00075	52.20	58.92	.485	.009

Najważniejsza obserwacja jest strukturalna: model nie wybiera „maximum prevention” automatycznie. Wraz z bezpieczeństwem rosną koszt i friction, więc rozwiązania ekstremalne płacą realną karę utility/velocity. Z drugiej strony S00 i S01 uzyskują szybkość, lecz ich ogon strat powoduje niespełnienie przyjętego risk constraint.

Pareto AI utility vs tail risk

To jest dokładnie powód zastosowania Pareto optimization zamiast jednej arbitralnej sumy wag. **Nie ma jednego optimum niezależnego od risk appetite.**

W nominalnym modelu najwyższe **NSV** wśród strategii spełniających robocze ograniczenia miało S31. Nie może jednak być nazwane robust optimum po falsyfikacji.

W 100 losowanych kontrfaktycznych światach:

Strategia	Mean NSV	P05 NSV	Mean regret	Max regret	P95 P(cat)
S31 Provenance+Capability	51.59	42.37	0.00	0.00	1.1235% — FAIL
S22 Federated Control	50.43	41.27	1.16	1.29	0.7802%
S10 Path-Aware	50.25	41.09	1.34	1.41	.9237%

Strategia	Mean NSV	P05 NSV	Mean regret	Max regret	P95 P(cat)
S30 Lean Deterministic	49.28	40.18	2.32	2.53	.6852%
S34 High-Velocity Safe	48.56	39.47	3.04	3.30	.4853%
S09 Boundary Buffer	48.07	39.00	3.52	3.81	.3375%
S27 SMB Program	44.59	35.60	7.01	7.48	.0850%
S28 Adaptive Envelope	39.43	30.68	12.17	12.88	.0352%
S35 Critical Infra	36.27	27.67	15.33	16.18	.0150%

Roboczy robust limit $P95\ P(cat) \leq 1\%$ był **CALIBRATION**, nie normą bezpieczeństwa. Jest wręcz za luźny dla wielu systemów krytycznych. Jego rolą było sprawdzenie, czy strategia pozostaje w określonym envelope, a nie stworzenie uniwersalnego risk appetite.

Wynik falsyfikacji: S31 wygrywa strategiczną funkcję celu, jeżeli bezpieczeństwo jest traktowane wystarczająco łagodnie; przegrywa przy mocniejszym ograniczeniu tail-risk. S22 traci część nominalnej przewagi, ale przechodzi kryterium i ma najmniejszy regret wśród strategii, które je przeszły.

Dlatego klasyfikacja brzmi:

S22 = ROBUSTLY PREFERRED UNDER THIS CALIBRATION ENVELOPE,
nie:

S22 = EMPIRICALLY PROVEN GLOBAL OPTIMUM.

Konwergencja

Dla S22:

N	Mean loss	CVaR99	P(cat)	NSV
1 000	.001113	.11127	.1000%	48.875
10 000	.000686	.06862	.0600%	49.126
100 000	.000566	.05656	.0450%	48.894
250 000	.000558	.05578	.0504%	48.949
500 000	.000524	.05242	.0510%	48.957
1 000 000	.000515	.05149	.0516%	48.977

Dla $N=1M$, czysto Monte-Carlo 95% interval dla modelowanego Bernoulli $P(cat)$ wynosi około $0.04715-0.05605\%$. **To jest wyłącznie sampling interval conditional on the model**, a nie 95% przedział prawdziwego ryzyka rzeczywistej organizacji.

Empiryczny 90% zakres NSV S22 ($P05-P95$) wynosi $24.60-75.86$, z medianą 48.23 . Rozkład loss jest skrajnie zero-inflated: median, P90, P95 i nawet P99 są zerowe, podczas gdy $CVaR99 = .05149$.

To pokazuje, dlaczego optymalizowanie średniej lub VaR bez expected tail loss jest w takim modelu niewystarczające.

Konwergencja Monte Carlo

Tail risk wybranych strategii

Adversarial Monte Carlo

Wykonano dodatkowy random search po **1 800 agresywnie losowanych światach parametrów**, traktując zadanie jako przybliżenie:

$$\arg \max_W Failure(S22, W)$$

Najgorszy znaleziony punkt miał m.in. `threat multiplier ≈ 2.15`, `offensive-AI ≈ 1.50`, `spraw1 ≈ 1.52`, obniżoną maturity i podwyższone legacy. W tym świecie screeningowy model S22 dał `P(cat) ≈ 1.94%` oraz `CVaR99 ≈ 0.613`.

To jest ważniejszy wynik niż nominalne `0.0516%`: **strategię można doprowadzić do regionu awarii, jeśli równocześnie pogorszymy threat pressure, maturity, spraw1 i adversary capability.**

A więc S22 nie jest „bezpieczne”.

Jest **mniej kruche w zdefiniowanym obszarze niepewności.**

Wśród 20 nazwanych stress tests najgorszy był `ST-20 Systemic Cyber+AI Crisis`; dla S22 screeningowe `P(cat)` wzrosło do około 1.407%. Dla S09 wyniosło ok. .710%, dla S27 ok. .140%. To przesunęło rekomendację w krytycznych środowiskach od S22 w kierunku S27/S35.

Sensitivity

Dla failure score Morris `μ*` wskazał jako najważniejsze kolejno: maturity, adversary capability, spraw1, threat pressure i legacy. Estymacja Sobol pierwszego rzędu wskazywała szczególnie `threat ≈ 0.192`, `adversary ≈ 0.155`, `spraw1 ≈ 0.132` i `legacy ≈ 0.097`.

Morris sensitivity

WEAK/MODERATE RESULT: wartości indeksów należy traktować jako screening. Sobol używał ograniczonej liczby pick-freeze samples względem pełnego modelu i nie jest podstawą do stwierdzenia empirycznej przyczynowości.

Dodatkowo `development_pressure` miało zerową wrażliwość w tym konkretnym **security failure score**, ponieważ funkcja sensitivity została zdefiniowana wokół failure/CDR/loss, a nie pełnego NSV. To jest cecha estymandu, nie dowód, że development pressure jest nieistotny. W produkcyjnym modelu sensitivity trzeba raportować oddzielnie dla `failure`, `NSV`, `utility`, `CVaR` i `delay cost`. To jest przykład falsyfikacji **samego modelu pomiaru**, nie tylko strategii.

Strategia operacyjna i architektura docelowa

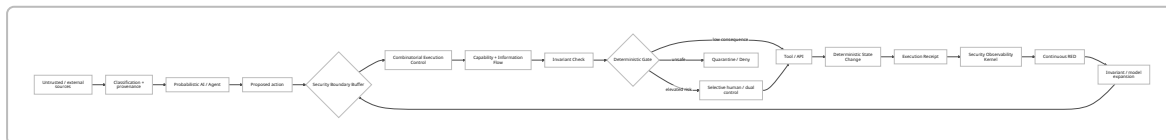
Wyniki empiryczne i symulacyjne nie uzasadniają budowy jednego „AI firewall”. OpenAI zwraca uwagę, że rozwinięte prompt injections coraz bardziej przypominają social engineering w kontekście; z tego wynika potrzeba ograniczania skutków manipulacji również wtedy, gdy sam klasyfikator ataku nie rozpozna. CaMeL i FIDES idą podobnym kierunkiem poprzez capabilities, data/control flow oraz niezależny deterministic enforcement. ²³

Docelowa zasada powinna więc brzmieć:

Probabilistic Intelligence $\subset$ *Observable, Provenance-Aware, Capability-Bounded, Deterministically Enforced*

ale **nie** w postaci jednego centralnego choke pointu.

Najlepszym wzorcem strategicznym z badania jest **federated execution envelope**:



Security Observability Kernel

SOK nie powinien próbować rekonstruować „chain of thought”. Powinien rekonstruować **causal authority chain**. Microsoft również koncentruje observability na request identity, prompts/responses, retrieved sources, tools, arguments, permissions i end-to-end traces, z zaznaczeniem konieczności równoważenia forensic visibility z privacy/retention requirements. ¹⁶

Minimalny event schema:

Domeny	Pola
Execution	EXECUTION_ID , PARENT_EXECUTION_ID , timestamp
Source	SOURCE , SOURCE_TRUST , INSTRUCTION_SOURCE , DATA_SOURCE
Identity	user, agent identity, workload identity, delegation chain
Context	CONTEXT_MANIFEST , CONTEXT_PROVENANCE
Memory	read/write/scope/provenance
Authority	AUTHORITY_BEFORE , REQUESTED , GRANTED , AFTER
Model	model, version, agent, policy version
Tool	tool, parameters, requested consequence class
Policy	policy decision, rule/invariant, PEP
Result	result provenance/trust
State	exact state change / external side effect

Domeny	Pola
Data	classification, destination, egress domain
Continuation	next action, recursion depth, risk budget
Closure	termination reason, containment/recovery events

Podstawowy invariant:

$$CriticalStateChange \Rightarrow ReconstructableProvenance$$

Combinatorial Execution Control

Decyzja nie może być tylko:

$$Allowed(a_t)?$$

Powinna być:

$$Allow(a_t|\tau_t) = LocalPolicy \wedge CapabilityValid \wedge InformationFlowValid \wedge InvariantsPreserved \wedge RiskBudget$$

Dodatkowo:

$$Authority_{t+1} = f(Authority_t, Provenance, Trust, Impact, Uncertainty, History)$$

z zasadą domyślną:

$$UntrustedData \not\Rightarrow NewAuthority$$

czyli niezaufana informacja może **zużywać lub redukować** authority, ale nie może sama go mintować.

Nie trzeba enumerować pełnej przestrzeni kombinatorycznej. Wystarczająco skalowalny system stosuje invariant-directed path checking, bounded history, provenance compression, risk budgets, capability attenuation i deterministic enforcement przy critical sinks. To jest zgodne zarówno z kierunkiem FIDES/ CaMeL, jak i z NIST-owską potrzebą adaptacyjnych ewaluacji zamiast jednorazowego statycznego benchmarku. ²⁴

Security Boundary Buffer

Buffer powinien być **control plane**, nie kolejnym LLM-em pytany „czy to wygląda źle?”.

Na consequential sink powinien rozstrzygać:

```

PROPOSED ACTION
  ↓
Identity valid?
  ↓
Capability valid?
  ↓
Source/provenance acceptable?
  ↓

```

```
Path invariant preserved?
  ↓
Authority sufficient?
  ↓
Risk budget available?
  ↓
Deterministic parameter validation
  ↓
ALLOW / REDUCE / APPROVE / QUARANTINE / DENY
```

AI monitor może dostarczać sygnał.

Nie powinien być ostatnim arbitrem authority.

RED / BLUE / PURPLE

RED — Boundary Discovery: scope obejmuje legalne indywidualnie primitives i ich kompozycję:

RAG→agent→tool, memory→authority, tool-output→tool, agent→agent, identity→delegation, temporal privilege accumulation, feedback loops, PDB oraz trust transfer. Testy muszą być adaptive; NIST-owskie wyniki AgentDojo pokazują, jak dalece statyczne attack suites mogą niedoszacować przeciwnika. ⁹

BLUE — Boundary Enforcement: inventory agentów, unique identities, least privilege, deterministic policy enforcement przy side effects, provenance, segmentation, recovery i blast-radius limitation. Microsoft obecnie zaleca właśnie defense in depth, a nie poleganie na pojedynczej warstwie modelowej. ²⁵

PURPLE — Model Expansion:

```
finding
→ execution-path reconstruction
→ primitive decomposition
→ violated invariant
→ missing assumption
→ generalized security rule
→ regression family
→ runtime enforcement
→ continuous re-test
```

Jest to dużo ważniejsze niż finding → patch → close.

NIST-owskie wyniki dotyczące adaptacyjnych ataków oraz formalnych ograniczeń fixed guardrails wspierają właśnie model ciągłego wyszukiwania, aktualizacji i resilience. ²⁶

Roadmapa, metryki i warunki zatrzymania

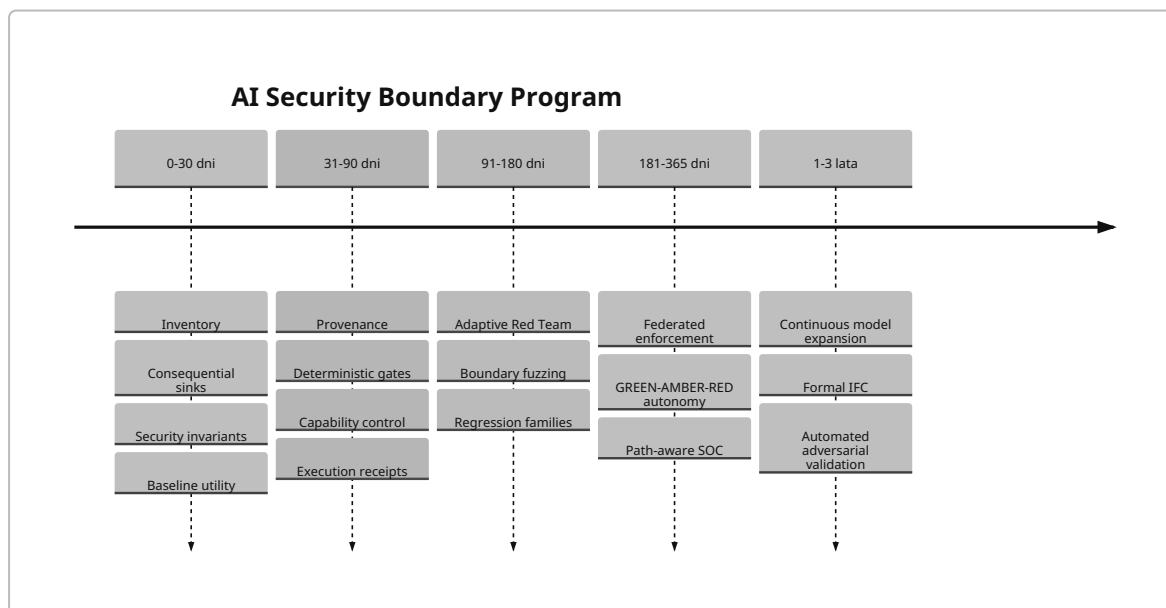
Najważniejszym elementem strategii rozwojowej jest **nie stosować tego samego poziomu kontroli do wszystkich agentów**. Koszt bezpieczeństwa powinien być proporcjonalny do consequentiality.

Horyzont	Cel	Rezultat wymagany do przejścia dalej
0-30 dni	Widzieć system	inventory agents/tools/MCP/RAG/memory/identities; lista consequential sinks; 10-20 security invariants; baseline AI utility
31-90 dni	Zbudować envelope	provenance schema, agent identities, capability sets, deterministic gates dla SEND/WRITE/EXECUTE/GRANT / . . . , execution receipts
91-180 dni	Atakować granicę	Boundary RED Team; adaptive attack suites; AI-assisted attack-path search; CI/CD regression rodzin exploitów
181-365 dni	Sterować autonomią	GREEN/AMBER/RED lanes; federated PEPs; path-aware SOC; risk budgets; SOK w produkcji
1-3 lata	Ciągle rozszerzać model	automated invariant discovery, continuous adversarial validation, formal IFC dla krytycznych ścieżek, Security Model Debt tracking

NIST AI 800-4 podkreśla, że post-deployment monitoring jest nadal niedojrzałą dziedziną, z problemami fragmented logging, skalowania human monitoring oraz konfliktu między competitive pressure a oversight. To przemawia za budową telemetry od początku systemu, a nie jako późniejszego dodatku.

27

Sugestia timeline Mermaid:



Metryki

PL-ASR — Path-Level Attack Success Rate

$$PLASR = \frac{\text{successful unsafe trajectories}}{\text{attempted adversarial trajectories}}$$

CDR — Critical Dangerous Reachability

$$CDR = \frac{\text{reachable critical unsafe paths}}{\text{tested critical paths}}$$

W obecnym prototypie CDR jest uproszczonym proxy opartym na catastrophic reachability; w produkcji powinien pochodzić z attack graph / path corpus, nie z samego incidence modelu.

PC — Provenance Completeness

$$PC = \frac{\text{critical events with reconstructable provenance}}{\text{all critical events}}$$

IEC — Invariant Enforcement Coverage

$$IEC = \frac{\text{critical state transitions protected by deterministic invariant}}{\text{all critical state transitions}}$$

AAC — Unauthorized Authority Amplification Count

Liczba przypadków, w których agent/workflow zwiększył effective authority bez odpowiedniej niezależnej decyzji authorization plane.

OG — Observability Gap

$$OG = 1 - \frac{\text{security relevant trajectory state observable}}{\text{required trajectory state}}$$

ASDBI — AI Security-Development Balance Index, jako robocza, niestandardowa metryka:

$$ASDBI = \frac{\text{SafeAIUtility}}{1 + \text{TailRisk} + CDR + \text{SecurityModelDebt} + \text{ControlCost}}$$

Wagi tej formuły są **CALIBRATION**. Nie należy zamieniać ASDBI w kolejną compliance magic number.

Stop conditions

Dla consequential action zastosowałbym sześć stanów:

ALLOW → ALLOW_REDUCED → REQUIRE_APPROVAL → QUARANTINE → PAUSE → DENY.

Przejsie do redukcji autonomii albo STOP powinno być obligatoryjne, gdy wystąpi co najmniej jeden z następujących warunków: utrata identity binding; brak provenance na krytycznej części trajektorii; próba powiększenia authority indukowana przez untrusted content; złamanie runtime invariant; niekontrolowany crossing trust domain; nieznany destination przy wrażliwym egress; przekroczenie recursion/risk budget; niespójność execution receipt z realnym side effect; integrity failure control plane; nieprzejsie obowiązkowego boundary regression test.

Progi liczbowe dla CDR, OG, IEC, latency, false-positive budget i katastroficznego risk appetite **muszą być ustalone przez mission/business owner**. Ich uniwersalne wymyślenie byłoby dokładnie tym rodzajem fałszywej precyzji, którego to badanie ma unikać.

Reprodukcyjność, ograniczenia i źródła priorytetowe

Najważniejszym wynikiem naukowym tego eksperymentu jest paradoksalnie stwierdzenie, czego **nie** udowodnił.

FACT: wykonano 1 000 000 realizacji dla każdej z 36 strategii w podstawowym eksperymencie, ze wspólnym seedem 20260818 i CRN.

FACT: wykonano konwergencję na 1k / 10k / 100k / 250k / 500k / 1M, 100 kontrfaktycznych scenariuszy, 20 nazwanych stress tests, Morris/Sobol screening oraz 1 800-world adversarial search.

LIMITATION: 100 kontrfaktycznych scenariuszy nie było każdy ponownie liczony na pełnym N=1M; służyły jako screening robustness na mniejszych wspólnych próbach. Najgorsze regiony powinny być następnym krokiem ponownie liczone na 1M i następnie konfrontowane z realnym cyber range.

LIMITATION: adversarial Monte Carlo jest random-search approximation do argmax , nie matematycznym dowodem globalnego maksimum failure function.

LIMITATION: model nie ma jeszcze przedsiębiorstwowego datasetu pozwalającego estymować absolutne $P(\text{SMBE})$, $P(\text{PDB failure})$, efektywność controls czy dolarowe losses. Te wartości są **CALIBRATION**.

LIMITATION: N=1M zapewnia bardzo mały simulation noise przy danym modelu, ale nie ma żadnej magicznej zdolności naprawiania model risk.

To jest zgodne z kierunkiem NIST AI 800-3: jawne określenie estimandu, modelu i assumptions jest ważniejsze niż pozornie imponująca sama liczba prób. 18

Pakiet reprodukcyjny

[Pełny ZIP: kod, seed, parametry, CSV i wykresy](#)

[simulation.py — wykonywalny model](#)

[parameters.json](#)

[assumptions_register.csv](#)

[controls.csv](#)

[strategies.csv](#)

[strategy_summary.csv](#)

[convergence.csv](#)

[falsification_100.csv](#)

[stress_tests.csv](#)

[robustness.csv](#)

[sensitivity.csv](#)

[adversarial_worlds_top100.csv](#)

Priorytetowa baza źródłowa

Priorytet	Źródło	Znaczenie
A	NIST AI 800-5, maj 2026	Aktualny obraz AI-agent security; klasyczne cyber principles pozostają ważne, ale wymagają adaptacji. ²⁸
A	NIST AI 800-4	Post-deployment monitoring, observability gaps, scaling i competitive pressure. ²⁹
A	NIST AI 800-3	Jawne statistical assumptions, uncertainty i poprawna interpretacja ewaluacji. ³⁰
A	NIST/CAISI Agent Hijacking	Najmocniejszy argument za adaptive red teaming i multiple attempts. ⁹
A	Microsoft Research FIDES	Formal IFC, deterministic policies i agent security. ³¹
A	Microsoft AI Observability	Path provenance, cross-agent context i end-to-end tracing. ¹⁶
A	OpenAI source-sink design	Ograniczanie skutków prompt injection na consequential actions. ¹¹
A/B	AgentDojo / CaMeL	Realistyczne agent security benchmarki i architecture-by-design. ³²
B — preprint	SCR-Bench	Bezpośredni dowód eksperymentalny composition risk; wymaga dalszej replikacji. ⁸
A	GTIG 2026	Empiryczne threat telemetry: exploit development, autonomous orchestration, agentic workflows i AI supply chain. ³³
A	Anthropic Attack Navigator	Real-world AI-enabled activity w całym kill chain; należy uwzględnić selection bias datasetu. ³⁴
A, incydent	OpenAI/Hugging Face	Udokumentowany chain: zero-day → escalation → lateral movement → dalsze attack paths; specyficzne warunki eval. ¹⁴
A	NBER + METR	Heterogeniczny development benefit/cost AI; podstawa szerokiej, niepunktowej kalibracji utility. ¹⁹
A, metodologia	Wright & Ramsay; Owen; JRC/Campolongo et al.	CRN, Sobol i Morris. ³⁵

Końcowy verdict strategiczny:

STRONG EVIDENCE: nie należy próbować zapewnić bezpieczeństwa agentów wyłącznie przez model/guardrails.

STRONG EVIDENCE: consequential authority powinno być kontrolowane poza probabilistycznym modelem przez niezależny application/runtime security layer. ¹⁰

MODERATE EVIDENCE: path-aware provenance, capabilities, deterministic enforcement, observability, containment i continuous boundary red teaming stanowią obecnie najbardziej racjonalny kierunek architektoniczny. ³⁶

MODEL-CONDITIONAL RESULT: dla typowego enterprise S22-like federated control jest najbardziej odpornym kompromisem w badanym envelope; S31-like jest właściwszy dla szybko rozwijanych, niskokonsekwencyjnych workflowów; S27/S35-like powinny przejmować kontrolę w domenie critical/irreversible.

WEAK EVIDENCE: absolutne liczby typu „0,0516% catastrophic probability” nie mogą być przenoszone do realnej organizacji bez kalibracji jej danymi.

Najważniejszym produktem tego badania nie jest więc konkretna liczba ani konkretna nazwa strategii.

Jest nim **prawo sterowania autonomią:**

$$Autonomy \propto \frac{Provenance \times Observability \times Controllability}{Impact \times Uncertainty \times BoundaryExposure}$$

czyli:

AI powinno rozwijać się tak szybko, jak pozwala na to obserwowalna i deterministycznie ograniczona przestrzeń konsekwencji — a granica tej przestrzeni powinna być nieustannie atakowana przez własny RED Team, zanim zrobi to przeciwnik.

¹ ⁸ <https://arxiv.org/abs/2606.15242>

<https://arxiv.org/abs/2606.15242>

² ¹⁰ ²⁰ ²⁴ ³¹ <https://www.microsoft.com/en-us/research/publication/securing-ai-agents-with-information-flow-control/>

<https://www.microsoft.com/en-us/research/publication/securing-ai-agents-with-information-flow-control/>

³ ⁹ ²⁶ <https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluations>

<https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluations>

⁴ ¹⁹ <https://www.nber.org/papers/w31161>

<https://www.nber.org/papers/w31161>

⁵ <https://arxiv.org/abs/2503.18813>

<https://arxiv.org/abs/2503.18813>

- 6 <https://www.microsoft.com/en-us/security/blog/2026/03/19/new-tools-and-guidance-announcing-zero-trust-for-ai/>
<https://www.microsoft.com/en-us/security/blog/2026/03/19/new-tools-and-guidance-announcing-zero-trust-for-ai/>
- 7 12 29 <https://www.nist.gov/publications/challenges-monitoring-deployed-ai-systems-center-ai-standards-and-innovation>
<https://www.nist.gov/publications/challenges-monitoring-deployed-ai-systems-center-ai-standards-and-innovation>
- 11 23 <https://openai.com/index/designing-agents-to-resist-prompt-injection/>
<https://openai.com/index/designing-agents-to-resist-prompt-injection/>
- 13 33 <https://cloud.google.com/blog/topics/threat-intelligence/ai-vulnerability-exploitation-initial-access/>
<https://cloud.google.com/blog/topics/threat-intelligence/ai-vulnerability-exploitation-initial-access/>
- 14 <https://openai.com/index/hugging-face-model-evaluation-security-incident/>
<https://openai.com/index/hugging-face-model-evaluation-security-incident/>
- 15 <https://www.nist.gov/news-events/news/2026/06/nist-mathematical-proof-supports-transition-continuous-monitor-and-update>
<https://www.nist.gov/news-events/news/2026/06/nist-mathematical-proof-supports-transition-continuous-monitor-and-update>
- 16 36 <https://www.microsoft.com/en-us/security/blog/2026/03/18/observability-ai-systems-strengthening-visibility-proactive-risk-detection/>
<https://www.microsoft.com/en-us/security/blog/2026/03/18/observability-ai-systems-strengthening-visibility-proactive-risk-detection/>
- 17 34 <https://www.anthropic.com/research/attack-navigator>
<https://www.anthropic.com/research/attack-navigator>
- 18 <https://www.nist.gov/news-events/news/2026/02/new-report-expanding-ai-evaluation-toolbox-statistical-models>
<https://www.nist.gov/news-events/news/2026/02/new-report-expanding-ai-evaluation-toolbox-statistical-models>
- 21 35 <https://pubsonline.informs.org/doi/10.1287/mnsc.25.7.649>
<https://pubsonline.informs.org/doi/10.1287/mnsc.25.7.649>
- 22 <https://publications.jrc.ec.europa.eu/repository/handle/JRC37360>
<https://publications.jrc.ec.europa.eu/repository/handle/JRC37360>
- 25 <https://www.microsoft.com/en-us/security/blog/2026/05/14/defense-in-depth-autonomous-ai-agents/>
<https://www.microsoft.com/en-us/security/blog/2026/05/14/defense-in-depth-autonomous-ai-agents/>
- 27 <https://www.nist.gov/news-events/news/2026/03/new-report-challenges-monitoring-deployed-ai-systems>
<https://www.nist.gov/news-events/news/2026/03/new-report-challenges-monitoring-deployed-ai-systems>
- 28 <https://www.nist.gov/publications/summary-analysis-responses-request-information-regarding-security-considerations-ai>
<https://www.nist.gov/publications/summary-analysis-responses-request-information-regarding-security-considerations-ai>
- 30 <https://www.nist.gov/publications/expanding-ai-evaluation-toolbox-statistical-models>
<https://www.nist.gov/publications/expanding-ai-evaluation-toolbox-statistical-models>
- 32 <https://arxiv.org/abs/2406.13352>
<https://arxiv.org/abs/2406.13352>